Name: Y. Guru Charan

Reg No: 192565020

Course Code: CSA-5803

Course Name: **DEVSECOPS ENGINEERING AND APPLICATION SECURITY**

CO2-AT2

A CASE STUDY ON

Threat Modelling and Risk Assessment of Critical Infrastructure Systems

ABSTRACT

Critical infrastructure systems, including power grids, transportation networks, water supply systems, and healthcare facilities, are essential for the functioning of modern society. With the rapid integration of digital technologies, Industrial Control Systems (ICS), and Internet of Things (IoT) devices, these infrastructures have become increasingly interconnected and efficient. However, this digital transformation has also significantly expanded the attack surface, making critical infrastructure systems highly vulnerable to cyber threats, system failures, and malicious attacks.

This case study focuses on the application of threat modeling and risk assessment techniques to a critical infrastructure system, specifically a power grid network. The study employs structured frameworks such as STRIDE for identifying potential threats and DREAD for evaluating associated risks. It systematically analyses system architecture, identifies critical assets, and examines possible vulnerabilities that could be exploited by attackers. Various threat scenarios, including unauthorized access, data manipulation, denial-of-service attacks, and insider threats, are explored to understand their potential impact on system reliability and public safety.

Furthermore, the study highlights the consequences of successful cyberattacks, such as large-scale power outages, economic disruption, and risks to human life. Based on the analysis, appropriate mitigation strategies are proposed, including the implementation of strong authentication mechanisms, network segmentation, real-time monitoring, intrusion detection systems, and regular security audits. The role of human factors, such as employee awareness and training, is also emphasized as a critical component of cybersecurity.

INTRODUCTION

Critical infrastructure systems are the backbone of modern society, providing essential services such as electricity, water supply, transportation, healthcare, and communication. These systems are highly interconnected and play a vital role in ensuring economic stability, public safety, and national security. Among them, power grid systems are considered one of the most crucial infrastructures, as almost all other sectors depend on a continuous and reliable supply of electricity.

In recent years, the rapid advancement of digital technologies has transformed traditional infrastructure into smart and automated systems. The integration of Information Technology (IT) with Operational Technology (OT), along with the adoption of Industrial Control Systems (ICS), Supervisory Control and Data Acquisition (SCADA) systems, and Internet of Things (IoT) devices, has significantly improved efficiency, monitoring, and control. However, this increased connectivity has also introduced new security challenges, making critical infrastructure systems more vulnerable to cyberattacks and system failures.

Cyber threats targeting critical infrastructure have become more sophisticated and frequent. Attackers may exploit vulnerabilities in software, communication networks, or human behavior to gain unauthorized access, disrupt operations, or manipulate system data. Incidents such as power outages caused by cyberattacks highlight the potential consequences, which can include economic losses, service disruptions, and risks to human lives. Therefore, ensuring the security and resilience of these systems has become a top priority for governments and organizations worldwide.

Threat modelling and risk assessment are essential techniques used to identify, analyze, and mitigate potential security risks in complex systems. Threat modelling helps in understanding possible attack vectors and identifying system weaknesses, while risk assessment evaluates the likelihood and impact of these threats. Together, they provide a structured approach to improving system security and decision-making.

Methodology

This case study follows a systematic and structured methodology to perform threat modelling and risk assessment for a critical infrastructure system, specifically a power grid. The approach begins with defining the scope of the system, which includes major components such as power generation units, transmission lines, substations, distribution networks, and supporting communication systems like SCADA. Both Information Technology (IT) and Operational Technology (OT) environments are considered to understand the complete system architecture and its boundaries.

The next step involves identifying and classifying critical assets within the system. These assets include physical components such as transformers and substations, digital components such as control software and databases, and human resources such as system operators and engineers. Each asset is evaluated based on the principles of confidentiality, integrity, and availability (CIA triad) to determine its importance and level of protection required.

Following asset identification, threat modelling is conducted using the STRIDE framework. This helps in identifying potential threats such as spoofing, tampering, repudiation, information disclosure, denial of service, and elevation of privilege. These threats are analyzed in relation to different system components to understand how attackers might exploit vulnerabilities.

Subsequently, a detailed vulnerability analysis is performed to identify weaknesses within the system. These vulnerabilities may include outdated software, weak authentication mechanisms, lack of encryption, improper network segmentation, and insufficient monitoring practices. Both technical vulnerabilities and human-related risks are taken into account during this stage.

Finally, the methodology includes continuous monitoring and evaluation of the system to ensure long-term security. Regular audits, vulnerability assessments, and updates are conducted to address emerging threats and maintain system resilience. This structured approach ensures a proactive and comprehensive framework for securing critical infrastructure systems.

THREAT MODELLING

Threat modelling is a systematic process used to identify, analyze, and understand potential security threats that can affect a system. In the context of critical infrastructure systems such as power grids, threat modelling plays a crucial role in identifying possible attack vectors and understanding how adversaries can exploit system vulnerabilities. Due to the interconnected nature of modern power grids, which integrate Information Technology (IT) and Operational Technology (OT), the attack surface has significantly increased, making threat modelling an essential component of cybersecurity planning.

In this case study, the STRIDE framework is used to perform threat modelling. STRIDE categorizes threats into six major types: Spoofing, Tampering, Repudiation, Information Disclosure, Denial of Service, and Elevation of Privilege. Each category represents a different type of attack that can compromise the system's security. Spoofing involves attackers impersonating legitimate users or devices to gain unauthorized access. Tampering refers to unauthorized modification of data or control signals within the system. Repudiation occurs when users deny their actions due to lack of proper logging and accountability mechanisms.

Information disclosure is another significant threat, where sensitive operational data is exposed to unauthorized entities, potentially leading to further exploitation. Denial of Service (DoS) attacks aim to disrupt the availability of the system by overwhelming network resources or critical components, which can result in service outages. Elevation of privilege occurs when an attacker gains higher access rights than permitted, allowing them to control critical system functions.

The threat modelling process involves analyzing each component of the power grid system, including SCADA systems, communication networks, control centres, and user interfaces. Potential threats are mapped to these components to understand where and how attacks can occur. Both external attackers, such as hackers and cybercriminals, and internal threats, such as malicious or negligent employees, are considered during the analysis.

FUTURE SCOPE

The future of threat modeling and risk assessment in critical infrastructure systems is expected to evolve significantly with the advancement of emerging technologies. As power grids and other infrastructure systems continue to adopt smart technologies, the integration of Artificial Intelligence (AI) and Machine Learning (ML) can play a vital role in enhancing security. These technologies can be used for predictive analysis, anomaly detection, and real-time threat identification, enabling systems to respond proactively to potential cyberattacks before they cause significant damage.

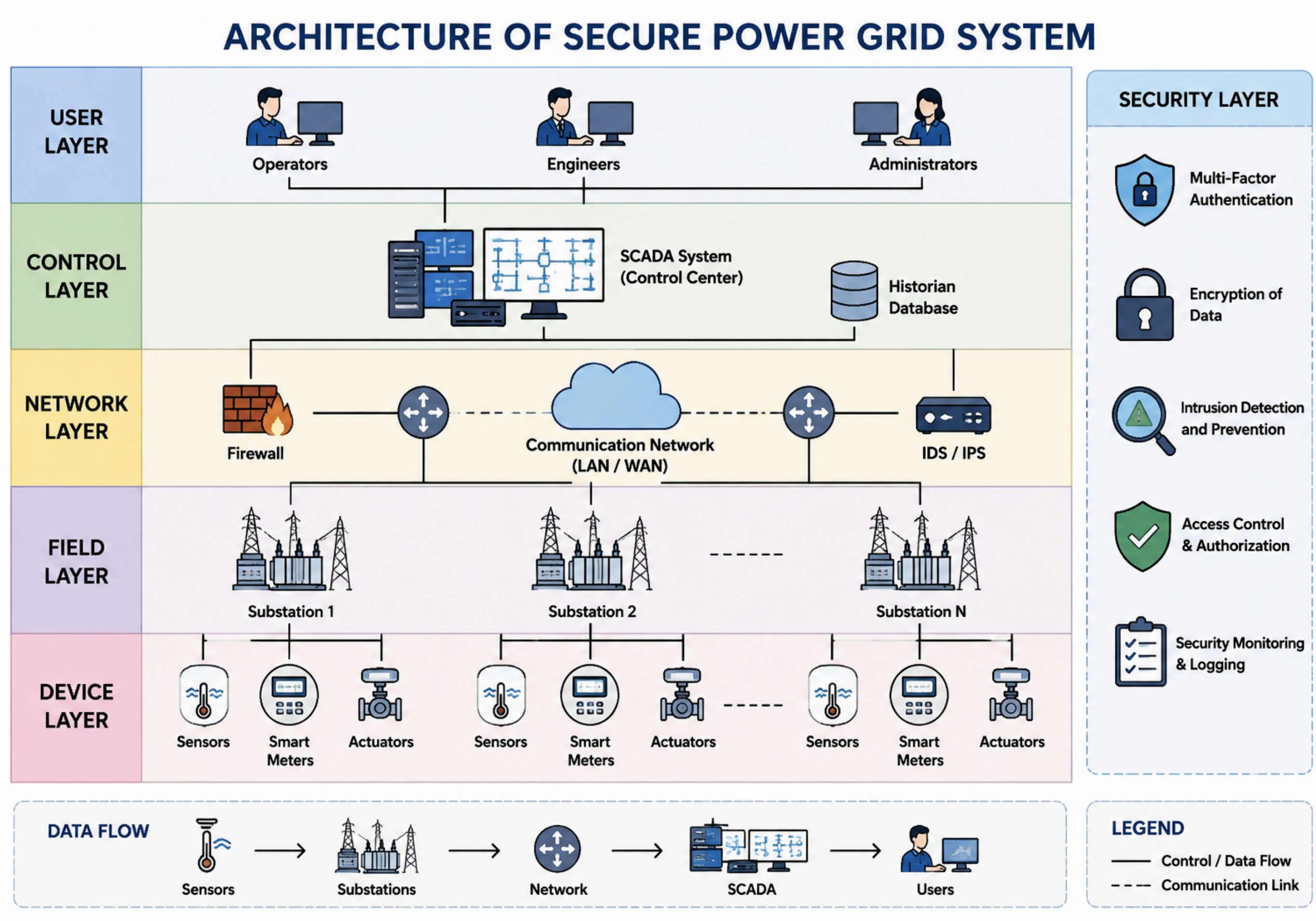
Another important area of future development is the implementation of advanced security architectures such as Zero Trust models. Unlike traditional security approaches, Zero Trust assumes that threats may exist both inside and outside the network, thereby enforcing strict verification for every user and device. This approach can significantly reduce the risk of unauthorized access and improve overall system security.

The adoption of blockchain technology is also gaining attention as a potential solution for securing communication and data integrity in critical infrastructure systems. Blockchain can provide a decentralized and tamper-resistant mechanism for data exchange, ensuring transparency and trust among different components of the system.

Furthermore, the development of resilient and self-healing infrastructure systems is an emerging trend. These systems are designed to automatically detect faults, isolate affected components, and restore normal operations with minimal human intervention. This capability is particularly important for power grids, where uninterrupted service is essential.

In addition to technological advancements, future efforts should focus on strengthening regulatory frameworks and cybersecurity policies. Governments and organizations need to establish standardized guidelines and compliance requirements to ensure consistent security practices across all critical infrastructure sectors. Regular training and awareness programs for employees will also play a crucial role in minimizing human-related risks.

ARCHITECTURE DIAGRAM



CONCLUSION

In conclusion, threat modeling and risk assessment play a vital role in ensuring the security and reliability of critical infrastructure systems. As modern infrastructures such as power grids become increasingly digitized and interconnected, they are exposed to a wide range of cyber threats and vulnerabilities. This case study has demonstrated how a structured approach, using methodologies like STRIDE for threat identification and DREAD for risk evaluation, can effectively identify potential risks and prioritize them based on their impact.

The analysis highlights that both technical and human factors contribute significantly to system vulnerabilities. Weak authentication mechanisms, outdated software, lack of proper network segmentation, and insufficient security awareness among personnel can increase the likelihood of successful attacks. By addressing these issues through appropriate mitigation strategies such as multi-factor authentication, intrusion detection systems, regular updates, and employee training, organizations can significantly enhance their security posture.

Furthermore, the study emphasizes the importance of continuous monitoring, regular audits, and proactive security measures to handle evolving cyber threats. Protecting critical infrastructure is not a one-time effort but an ongoing process that requires constant evaluation and improvement. Ensuring the resilience of such systems is essential not only for operational efficiency but also for public safety and national security.

Overall, this case study concludes that adopting a comprehensive and systematic approach to threat modeling and risk assessment is essential for safeguarding critical infrastructure systems. With the proper implementation of security controls and continuous improvement practices, organizations can minimize risks, prevent disruptions, and ensure the reliable delivery of essential services.